



Escuela Técnica Superior de
Ingeniería Informática

SEGURIDAD EN SISTEMAS INFORMÁTICOS Y EN INTERNET

PAI-3.

**VULNAWEB. AUDITORÍA DE SEGURIDAD EN SISTEMAS
INFORMÁTICOS Y ANÁLISIS DE VULNERABILIDADES EN
APLICACIONES WEB PARA EMPRESA DE COMERCIO
ELECTRÓNICO.**

SECURITY TEAM 2

Alejandro Fernández Orozco
Alejandro Morilla García

RESUMEN EJECUTIVO	3
TAREA 1	3
TAREA 2	5
TAREA 3	8
TAREA 4	9
CONCLUSIONES	10
ANEXO	11

RESUMEN EJECUTIVO

La empresa de comercio electrónico ha solicitado nuestra colaboración para garantizar la seguridad de sus sistemas informáticos, aplicaciones web y plataformas utilizadas por los clientes. El objetivo es asegurar que tanto los sistemas internos, como los navegadores empleados por los usuarios, se conecten de manera segura a través de HTTPS. Para cumplir con esta solicitud, se han establecido tres objetivos clave:

1. Realizar una auditoría exhaustiva de seguridad en los sistemas informáticos empleados por los empleados de la empresa, incluyendo ordenadores de escritorio, portátiles y dispositivos móviles.
2. Configurar una herramienta especializada en el análisis de vulnerabilidades web, que permita no solo la detección de posibles brechas de seguridad, sino también asegurar una trazabilidad completa de todas las solicitudes y respuestas HTTP/HTTPS.
3. Auditar las aplicaciones web corporativas con el fin de identificar y mitigar posibles vulnerabilidades de seguridad, haciendo especial énfasis en aquellas relacionadas con inyecciones SQL.

Gracias a la implementación de estas medidas, podemos afirmar con confianza que los sistemas de seguridad de la empresa han alcanzado un nivel de fiabilidad significativamente elevado, lo que garantiza una mayor integridad en la gestión de los datos con los que opera.

TAREA 1

Antes de iniciar la primera tarea, decidimos crear y configurar una máquina virtual con ubuntu 24.04 para realizar todas las tareas requeridas. Una vez creada la máquina, lo primero que hicimos fue instalar Lynis, herramienta que permite realizar auditorías de seguridad fácilmente, además de dar un hardening index (*Fig. 1*).

Tras ejecutarlo nos daba un índice de hardening de 58. En los resultados aparecen 2 warnings y 40 sugerencias, al solucionar los warnings e implementar algunas de las sugerencias hemos conseguido alcanzar un índice de hardening de 68. Estas han sido las implementaciones:

[PKGS-7392]

Para solucionar este primer warning hay que hacer `sudo apt update` y `upgrade`. Este warning aparece cuando encuentra que un paquete puede contener alguna

[FIRE-4512]

Este warning hace referencia a las iptables, ocurre debido a que está activo el módulo pero no tienen reglas activas. Como no podemos desactivar este módulo por completo en Ubuntu, desactivamos este test en el archivo "indicar archivo"

Una vez eliminados estos warnings, el índice sube a 64 (*Fig. 8*), vamos a seleccionar varias sugerencias a implementar que nos aumentaran la seguridad de nuestros dispositivos:

[PKGS-7370]

Instalamos el paquete debsums utility

[PKGS-7394]

Instalamos el paquete apt-show-versions

[DEB-0880]

Instalamos fail2ban para bloquear hosts que hayan cometido múltiples errores de autenticación.

[AUTH-9286]

En el archivo /etc/login.defs, configuramos fecha máxima y mínima para la contraseña

Una vez completadas todas estas tareas, el índice de hardening asciende a 68. (*Fig. 9*)

TAREA 2

Se nos ha solicitado evaluar el nivel de seguridad de nuestros dispositivos móviles y seguir unas recomendaciones específicas. Para ello, hemos utilizado la aplicación **CONAN Mobile** para realizar un análisis detallado de la seguridad de nuestros dispositivos. Esta herramienta nos ha permitido identificar posibles vulnerabilidades y puntos de mejora, proporcionando una base para aplicar las recomendaciones dadas y fortalecer la protección de nuestros dispositivos móviles. (Fig 10 y Fig 11)

Respecto a la configuración del dispositivo:

Lo primero que se nos solicita es deshabilitar la instalación de software desde orígenes desconocidos. Para hacerlo, seguimos estos pasos:

1. Vamos a **Ajustes** en el dispositivo.
2. Accedemos a **Aplicaciones**.
3. Seleccionamos **Acceso especial**.
4. Elegimos la opción **Instalar aplicaciones desconocidas**.
5. Buscamos **Chrome** (o el navegador que estemos utilizando).
6. Desactivamos la opción que permite la instalación de aplicaciones de orígenes desconocidos.

Este ajuste ayuda a prevenir la instalación de aplicaciones maliciosas que no provienen de fuentes confiables.

(Fig 12 y Fig 13)

La siguiente tarea consiste en verificar si nuestro dispositivo está rooteado. Para ello, utilizamos la aplicación **Root Checker** disponible en la Play Store. Los pasos a seguir son:

1. Descargamos e instalamos la aplicación **Root Checker** desde la Play Store.
2. Aceptamos todos los permisos solicitados por la aplicación.
3. Pulsamos sobre el botón **"Verificar Root"**.

Al hacerlo, la aplicación nos mostrará un mensaje indicando si el dispositivo está rooteado o no. En mi caso, el dispositivo no está rooteado.

(Fig 14 y Fig 15)

Para asegurarnos de que todas las actualizaciones del fabricante del dispositivo, del sistema operativo y de la aplicación del navegador estén instaladas, seguimos los siguientes pasos:

1. **Actualizar el sistema operativo:**
 - Vamos a **Ajustes**.
 - Seleccionamos **Sistema**.
 - Accedemos a **Actualizaciones del sistema**.
 - Pulsamos en **Buscar actualizaciones** para comprobar si hay alguna disponible. Si existe una actualización, la descargamos e instalamos.
2. **Actualizar el navegador:**

- Abrimos la **Play Store**.
- Buscamos **Google Chrome** en la barra de búsqueda.
- Verificamos si hay una opción para **actualizar** la aplicación. Si es necesario, pulsamos en **Actualizar**.

Con esto, aseguramos que tanto el sistema como las aplicaciones estén actualizados y protegidos con las últimas mejoras y parches de seguridad.

(Fig 16 y Fig 17)

Para verificar la seguridad de nuestra conexión a internet y asegurarnos de no conectarnos a redes Wi-Fi sin seguridad adecuada o con SSID oculto, seguimos estos pasos:

1. Vamos a **Ajustes** en el dispositivo.
2. Seleccionamos **Wi-Fi**.
3. Buscamos y tocamos sobre la red a la que estamos conectados, en este caso **Movistar D768**.

Aquí podemos ver si la red está utilizando una seguridad adecuada, como WPA2 o WPA3. Es importante que la red esté protegida con una contraseña robusta y no utilice una configuración de SSID oculta, ya que esto podría dificultar la detección de la red y aumentar el riesgo de seguridad.

(Fig 18)

Por último, nos piden desactivar el Bluetooth durante las conexiones web para evitar posibles vulnerabilidades. Para verificar esto, seguimos estos pasos:

1. Vamos a **Ajustes** en el dispositivo.
2. Seleccionamos **Aplicaciones**.
3. Tocamos **Ver todas las aplicaciones**.
4. Buscamos **Chrome** y seleccionamos la aplicación.
5. Accedemos a **Permisos**.
6. Verificamos que **Chrome** no tiene permisos sobre las funcionalidades de **Bluetooth**.

De esta manera, nos aseguramos de que el navegador no tiene acceso al Bluetooth durante las conexiones web, lo que ayuda a reducir riesgos de seguridad.

(Fig 19)

Con respecto a las aplicaciones instaladas, es importante asegurarse de no tener aplicaciones maliciosas o sospechosas de serlo. Para comprobarlo, seguimos estos pasos:

1. Abrimos la **Play Store** en el dispositivo.
2. Vamos a **Gestionar apps y dispositivo**.
3. Seleccionamos la pestaña **Play Protect**.
4. En esta sección, Play Protect nos notificará si hay alguna aplicación potencialmente maliciosa o insegura en el dispositivo.

De esta forma, podemos identificar y eliminar aplicaciones que representen un riesgo para la seguridad del dispositivo.

(Fig 20)

Para asegurarnos de que no haya conexiones de red abiertas de aplicaciones diferentes al navegador que puedan considerarse sospechosas, seguimos estos pasos:

1. Vamos a **Ajustes** en el dispositivo.
2. Seleccionamos **Tarjeta SIM y red móvil**.
3. Accedemos a **Uso de datos**.
4. Luego, tocamos **Uso de datos de las aplicaciones**.
5. En esta lista, verificamos que no haya ninguna aplicación desconocida o sospechosa utilizando datos en segundo plano.

Si encontramos alguna aplicación que no reconocemos o que nos parece potencialmente maliciosa, podemos tomar las medidas necesarias, cómo deshabilitar el acceso a los datos o eliminar la aplicación.

(Fig 21 y Fig 22)

Para asegurarnos de que otras aplicaciones no tengan permisos para leer información sobre lo que el navegador descarga o envía, seguimos estos pasos:

1. Vamos a **Ajustes** en el dispositivo.
2. Seleccionamos **Aplicaciones**.
3. Tocamos **Ver todas las aplicaciones**.
4. Buscamos y seleccionamos **Chrome**.
5. Accedemos a **Permisos**.
6. Deshabilitamos los permisos relacionados con **Archivos y multimedia**.

Con esto, garantizamos que otras aplicaciones no puedan acceder a la información del navegador, como archivos descargados o datos enviados, lo que mejora la privacidad y seguridad del dispositivo.

(Fig 23)

Con estos cambios y comprobaciones realizados en el dispositivo móvil, podemos estar seguros de que hemos fortalecido significativamente su seguridad. Al deshabilitar opciones riesgosas, verificar permisos y realizar ajustes en las aplicaciones, hemos implementado una serie de medidas preventivas que contribuyen a proteger la privacidad y los datos en el dispositivo móvil, reduciendo así el riesgo de amenazas y vulnerabilidades.

TAREA 3

Para esta tarea, hemos instalado un servidor de pruebas y configurado una herramienta DAST (Dynamic Application Security Testing) para realizar pruebas dinámicas de seguridad en la aplicación.

(Fig 24)

Para el servidor de pruebas, hemos configurado OWASP Mutillidae II como un contenedor en Docker. Este proyecto consiste en una página web intencionalmente vulnerable, donde realizaremos todas las pruebas de seguridad necesarias.

Para llevar a cabo el análisis DAST, hemos elegido OWASP ZAP. Hemos instalado y configurado esta herramienta para que se comunique adecuadamente con el navegador web. Esto incluyó la configuración de los puertos en ambas aplicaciones y la descarga e instalación en el navegador del certificado generado por ZAP.

(Fig 25, 26, 27 y 28)

Con toda la configuración completada, ahora podemos interceptar y visualizar toda la información transmitida entre el usuario de la web y el servidor. Esto nos permite capturar toda la comunicación entre ambas partes, actuando de manera similar a un ataque Man in the Middle (MitM).

(Fig 29 y 30)

En la imagen (Índice de captura de pantalla de la app de las tramas) se muestran todas las acciones que se llevan a cabo en la página, incluyendo intentos de inicio de sesión y las contraseñas correspondientes. Además, realizamos una segunda prueba utilizando **breakpoints**. Con esta función, podemos controlar la respuesta que enviamos: podemos aceptar la respuesta predeterminada simplemente continuando con el flujo (**play**) o modificarla según lo que deseemos.

En el área de **Request**, es posible buscar en el código HTML el tipo de respuesta específica que queremos enviar, permitiéndonos personalizar la interacción con el servidor según nuestras necesidades de prueba.

(Fig 31)

TAREA 4

Finalmente, realizamos un análisis de vulnerabilidades mediante una inyección SQL en el formulario de inicio de sesión de la página. Para ello, activamos la captura de paquetes con **breakpoints**, ingresamos un usuario y contraseña, en este caso "prueba2", y detenemos la transmisión. A continuación, utilizamos la herramienta **Fuzzer**, donde añadimos la inyección SQL y ejecutamos 169 pruebas para evaluar las posibles vulnerabilidades de la aplicación.

(Fig 32)

Las pruebas en las que el estado aparece como "Reflected" son las que muestran mayor efectividad, es decir, aquellas en las que hemos logrado vulnerar la seguridad de la página. Estas pruebas permiten acceder al sistema ya sea modificando la contraseña o incluso sin necesidad de introducir ninguna.

(Fig 33)

Realizamos una prueba de acceso utilizando una de las vulnerabilidades detectadas: **password='a'**. Ejecutamos una solicitud de inicio de sesión con el mismo usuario y la contraseña "a", y el acceso fue exitoso, permitiéndonos entrar en la sesión.

(Fig 34 y 35)

Para evitar vulnerabilidades de inyección SQL, es fundamental implementar buenas prácticas de seguridad en el desarrollo de aplicaciones web. Algunas recomendaciones clave son:

- **Usar Consultas Parametrizadas o Prepared Statements:** Emplear consultas parametrizadas o *prepared statements* en lugar de concatenar directamente consultas SQL con datos proporcionados por el usuario. Esto permite separar los datos de la lógica de la consulta, reduciendo el riesgo de inyección SQL al evitar que los datos de entrada se interpreten como código SQL.

```
cursor.execute("SELECT * FROM usuarios WHERE usuario = ? AND contraseña = ?",  
(nombre_usuario, contraseña))
```

- **Validación y Escapado de Datos:** Validar y escapar correctamente todos los datos de entrada del usuario antes de incorporarlos en una consulta SQL. Esto implica revisar que los datos cumplan con el formato esperado y eliminar o escapar caracteres especiales que podrían ser utilizados para inyectar código malicioso. Estas medidas previenen que los datos sean interpretados de forma errónea por la base de datos, reforzando la seguridad de la aplicación.

```
$nombre_usuario = mysql_real_escape_string($conexión, $_POST['nombre_usuario']);  
$contraseña = mysql_real_escape_string($conexión, $_POST['contraseña']);  
$consulta = "SELECT * FROM usuarios WHERE usuario='$nombre_usuario' AND  
contraseña='$contraseña';
```

- **Aplicar el Principio del Mínimo Privilegio:** Asegurarse de que la cuenta de base de datos utilizada por la aplicación tenga solo los privilegios necesarios para ejecutar las operaciones requeridas. Evitar el uso de cuentas con privilegios excesivos que puedan ser explotadas en caso de una vulnerabilidad.
- **Utilizar Listas Blancas (Whitelisting):** En lugar de emplear listas negras (blacklisting), que se centran en bloquear patrones específicos de ataque, es más seguro utilizar listas blancas. Esto implica permitir solo ciertos tipos de entrada válidos y rechazar todo lo demás, limitando las posibilidades de inyección maliciosa.
- **Implementar Herramientas de Seguridad:** Utilizar herramientas de seguridad, como firewalls de aplicaciones web (WAF), que pueden detectar y prevenir ataques de inyección SQL. Estas herramientas ofrecen una capa adicional de protección frente a ataques externos.
- **Realizar Pruebas de Seguridad de manera Regular:** Llevar a cabo pruebas de seguridad de forma continua, como análisis de vulnerabilidades y pruebas de penetración, para identificar y resolver posibles fallos de seguridad antes de que se conviertan en amenazas reales. Esto ayuda a mantener la aplicación robusta frente a nuevos vectores de ataque.

Estas recomendaciones son fundamentales para reducir significativamente el riesgo de inyección SQL en aplicaciones web. Es crucial entender que la seguridad no debe ser vista como una solución única, sino como un enfoque multifacético. La implementación de varias capas de defensa, como consultas parametrizadas, validación de datos, control de privilegios y herramientas de seguridad adicionales, proporciona una protección más robusta. La combinación de estas prácticas es clave para proteger eficazmente una aplicación contra una amplia gama de amenazas.

CONCLUSIONES

Después de una auditoría exhaustiva y la implementación de mejoras, hemos logrado reforzar significativamente la seguridad de los sistemas informáticos y dispositivos móviles de la empresa de comercio electrónico. Desde ajustes en la máquina virtual hasta la adopción de medidas preventivas en los dispositivos, se ha logrado una mejora considerable en la protección.

Las pruebas de inyección SQL y el uso de herramientas DAST (Dynamic Application Security Testing) nos permitieron identificar y corregir vulnerabilidades críticas, asegurando la integridad de los datos y estableciendo un entorno mucho más seguro para la empresa.

ANEXO

```
Lynis security scan details:
Hardening index : 58 [#####]
Tests performed : 249
Plugins enabled : 1

Components:
- Firewall [V]
- Malware scanner [X]

Scan mode:
Normal [V] Forensics [ ] Integration [ ] Pentest [ ]

Lynis modules:
- Compliance status [?]
- Security audit [V]
- Vulnerability scan [V]

Files:
- Test and debug information : /var/log/lynis.log
- Report data : /var/log/lynis-report.dat

=====

Lynis 3.0.9

Auditing, system hardening, and compliance for UNIX-based systems
(Linux, macOS, BSD, and others)

2007-2021, CISofy - https://cisofy.com/lynis/
Enterprise support available (compliance, plugins, interface and tools)
```

Fig 1.

```
- [ Lynis 3.0.9 Results ] -

Warnings (2):
-----
! Found one or more vulnerable packages. [PKGS-7392]
  https://cisofy.com/lynis/controls/PKGS-7392/

! iptables module(s) loaded, but no rules active [FIRE-4512]
  https://cisofy.com/lynis/controls/FIRE-4512/
```

Fig 2

```
Suggestions (40):
-----
* This release is more than 4 months old. Check the website or GitHub to see if there is an update available. [LYNIS]
  https://cisofy.com/lynis/controls/LYNIS/

* Install libpam-tmpdir to set $TMP and $TMPDIR for PAM sessions [DEB-0280]
  https://cisofy.com/lynis/controls/DEB-0280/

* Install apt-listbugs to display a list of critical bugs prior to each APT installation. [DEB-0810]
  https://cisofy.com/lynis/controls/DEB-0810/

* Install apt-listchanges to display any significant changes prior to any upgrade via APT. [DEB-0811]
  https://cisofy.com/lynis/controls/DEB-0811/

* Install needrestart, alternatively to debian-goodies, so that you can run needrestart after upgrades to determine which daemons are using old versions of libraries and need restarting. [DEB-0831]
  https://cisofy.com/lynis/controls/DEB-0831/

* Install fail2ban to automatically ban hosts that commit multiple authentication errors. [DEB-0880]
  https://cisofy.com/lynis/controls/DEB-0880/

* Set a password on GRUB boot loader to prevent altering boot configuration (e.g. boot in single user mode without password) [BOOT-5122]
  https://cisofy.com/lynis/controls/BOOT-5122/
```

Fig 3

```

* Consider hardening system services [BOOT-5264]
- Details : Run '/usr/bin/systemd-analyze security SERVICE' for each service
https://cisofy.com/lynis/controls/BOOT-5264/

* If not required, consider explicit disabling of core dump in /etc/security/limits.conf file [KRNL-5820]
https://cisofy.com/lynis/controls/KRNL-5820/

* Check PAM configuration, add rounds if applicable and expire passwords to encrypt with new values [AUTH-9229]
https://cisofy.com/lynis/controls/AUTH-9229/

* Configure password hashing rounds in /etc/login.defs [AUTH-9230]
https://cisofy.com/lynis/controls/AUTH-9230/

* When possible set expire dates for all password protected accounts [AUTH-9282]
https://cisofy.com/lynis/controls/AUTH-9282/

* Configure minimum password age in /etc/login.defs [AUTH-9286]
https://cisofy.com/lynis/controls/AUTH-9286/

* Configure maximum password age in /etc/login.defs [AUTH-9286]
https://cisofy.com/lynis/controls/AUTH-9286/

* Default umask in /etc/login.defs could be more strict like 027 [AUTH-9328]
https://cisofy.com/lynis/controls/AUTH-9328/

* To decrease the impact of a full /home file system, place /home on a separate partition [FILE-6310]
https://cisofy.com/lynis/controls/FILE-6310/

```

Fig 4

```

* To decrease the impact of a full /tmp file system, place /tmp on a separate partition [FILE-6310]
https://cisofy.com/lynis/controls/FILE-6310/

* To decrease the impact of a full /var file system, place /var on a separate partition [FILE-6310]
https://cisofy.com/lynis/controls/FILE-6310/

* Disable drivers like USB storage when not used, to prevent unauthorized storage or data theft [USB-1000]
https://cisofy.com/lynis/controls/USB-1000/

* Check DNS configuration for the dns domain name [NAME-4028]
https://cisofy.com/lynis/controls/NAME-4028/

* Install debsums utility for the verification of packages with known good database. [PKGS-7370]
https://cisofy.com/lynis/controls/PKGS-7370/

* Update your system with apt-get update, apt-get upgrade, apt-get dist-upgrade and/or unattended-upgrades [PKGS-7392]
https://cisofy.com/lynis/controls/PKGS-7392/

* Install package apt-show-versions for patch management purposes [PKGS-7394]
https://cisofy.com/lynis/controls/PKGS-7394/

* Determine if protocol 'dccp' is really needed on this system [NETW-3200]
https://cisofy.com/lynis/controls/NETW-3200/

* Determine if protocol 'sctp' is really needed on this system [NETW-3200]
https://cisofy.com/lynis/controls/NETW-3200/

* Determine if protocol 'rds' is really needed on this system [NETW-3200]
https://cisofy.com/lynis/controls/NETW-3200/

```

Fig 5

```

* Determine if protocol 'tipc' is really needed on this system [NETW-3200]
https://cisofy.com/lynis/controls/NETW-3200/

* Access to CUPS configuration could be more strict. [PRNT-2307]
https://cisofy.com/lynis/controls/PRNT-2307/

* Enable logging to an external logging host for archiving purposes and additional protection [LOGG-2154]
https://cisofy.com/lynis/controls/LOGG-2154/

* Check what deleted files are still in use and why. [LOGG-2190]
https://cisofy.com/lynis/controls/LOGG-2190/

* Add a legal banner to /etc/issue, to warn unauthorized users [BANN-7126]
https://cisofy.com/lynis/controls/BANN-7126/

* Add legal banner to /etc/issue.net, to warn unauthorized users [BANN-7130]
https://cisofy.com/lynis/controls/BANN-7130/

* Enable process accounting [ACCT-9622]
https://cisofy.com/lynis/controls/ACCT-9622/

* Enable sysstat to collect accounting (disabled) [ACCT-9626]
https://cisofy.com/lynis/controls/ACCT-9626/

* Enable auditd to collect audit information [ACCT-9628]
https://cisofy.com/lynis/controls/ACCT-9628/

* Install a file integrity tool to monitor changes to critical and sensitive files [FINT-4350]
https://cisofy.com/lynis/controls/FINT-4350/

* Determine if automation tools are present for system management [TOOL-5002]
https://cisofy.com/lynis/controls/TOOL-5002/

```

Fig 6

```

* Consider restricting file permissions [FILE-7524]
- Details : See screen output or log file
- Solution : Use chmod to change file permissions
             https://cisofy.com/lynis/controls/FILE-7524/

* One or more sysctl values differ from the scan profile and could be tweaked [KRNL-6000]
- Solution : Change sysctl value or disable test (skip-test=KRNL-6000:<sysctl-key>)
             https://cisofy.com/lynis/controls/KRNL-6000/

* Harden the system by installing at least one malware scanner, to perform periodic file system scans [HRDN-7230]
- Solution : Install a tool like rkhunter, chkrootkit, OSSEC
             https://cisofy.com/lynis/controls/HRDN-7230/

```

Fig 7

```

Lynis security scan details:

Hardening index : 64 [#####          ]
Tests performed : 249
Plugins enabled : 1

Components:
- Firewall           [V]
- Malware scanner    [X]

Scan mode:
Normal [V]  Forensics [ ]  Integration [ ]  Pentest [ ]

Lynis modules:
- Compliance status  [?]
- Security audit     [V]
- Vulnerability scan [V]

Files:
- Test and debug information : /var/log/lynis.log
- Report data                : /var/log/lynis-report.dat

```

=====

Lynis 3.0.9

Auditing, system hardening, and compliance for UNIX-based systems
(Linux, macOS, BSD, and others)

Fig 8

```

Lynis security scan details:

Hardening index : 68 [#####          ]
Tests performed : 249
Plugins enabled : 1

Components:
- Firewall           [V]
- Malware scanner    [X]

Scan mode:
Normal [V]  Forensics [ ]  Integration [ ]  Pentest [ ]

Lynis modules:
- Compliance status  [?]
- Security audit     [V]
- Vulnerability scan [V]

Files:
- Test and debug information : /var/log/lynis.log
- Report data                : /var/log/lynis-report.dat

```

=====

Lynis 3.0.9

Fig 9

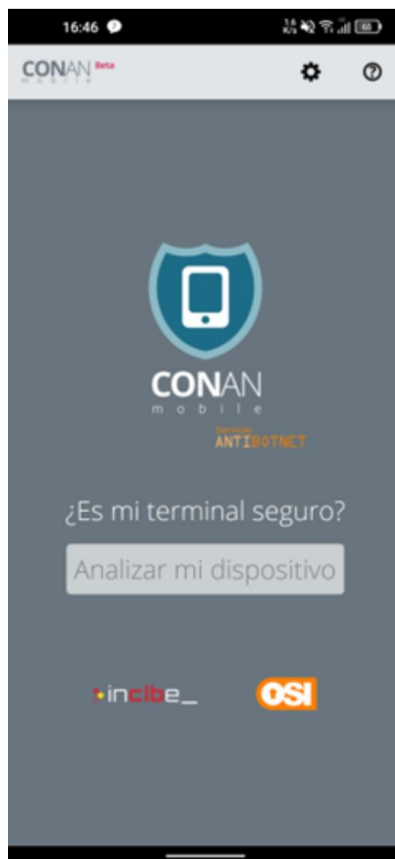


Fig 10



Fig 11

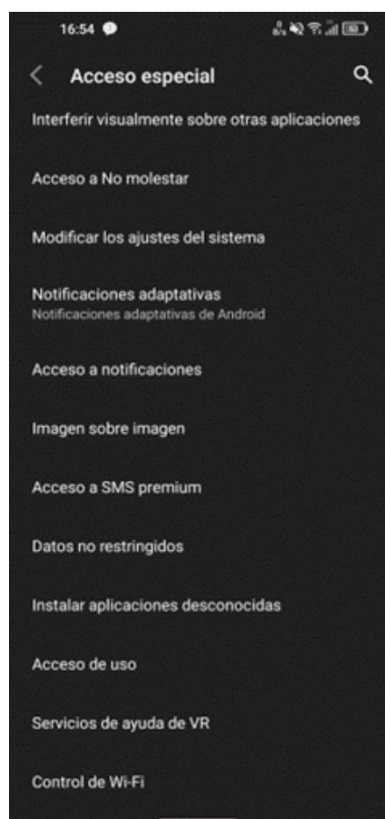


Fig 12

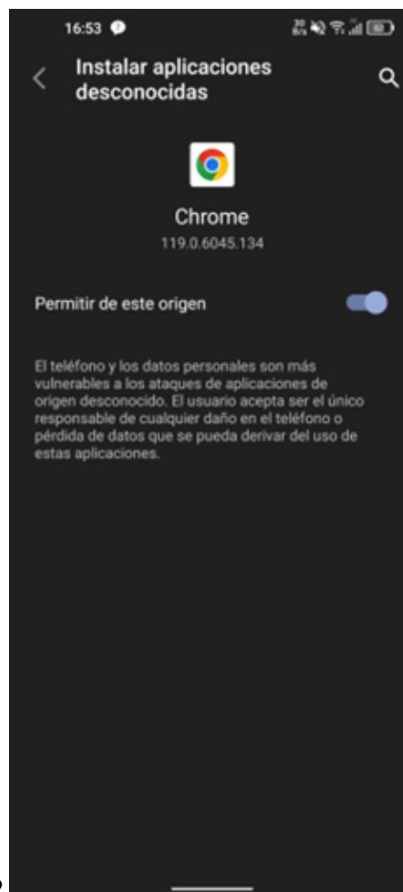


Fig 13

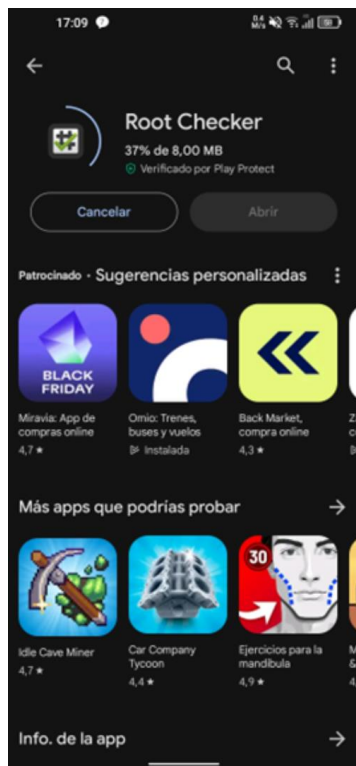


Fig 14

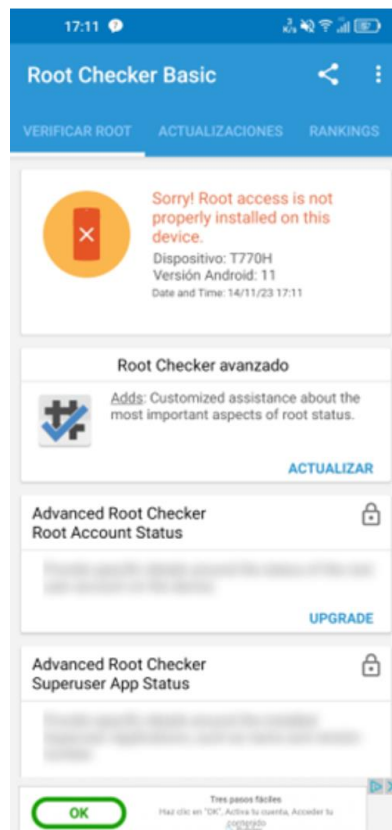


Fig 15



Fig 16



Fig 17

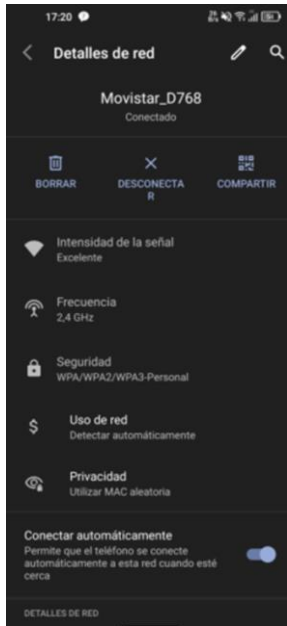


Fig 18

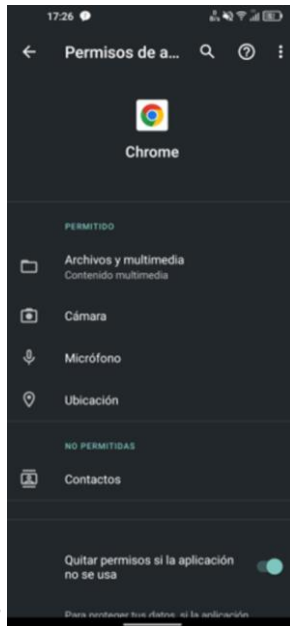


Fig 19

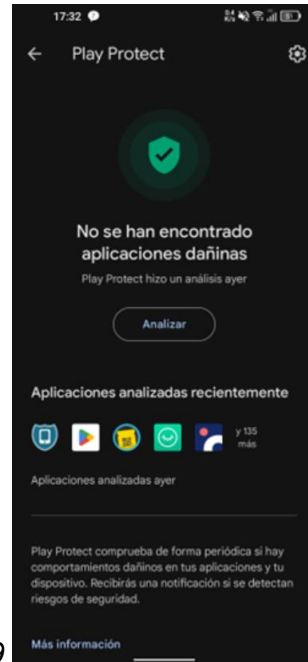


Fig 20

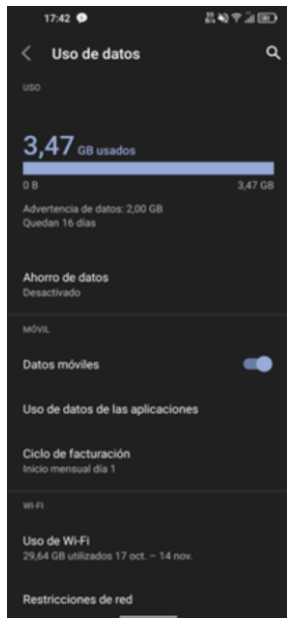


Fig 21

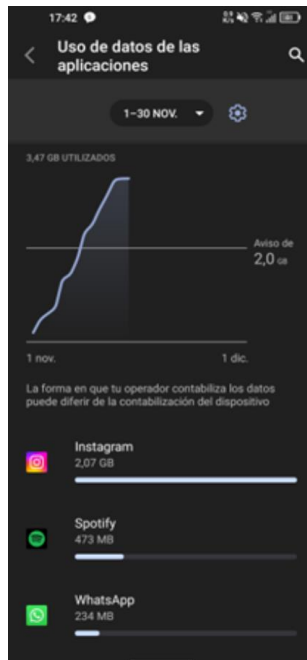


Fig 22

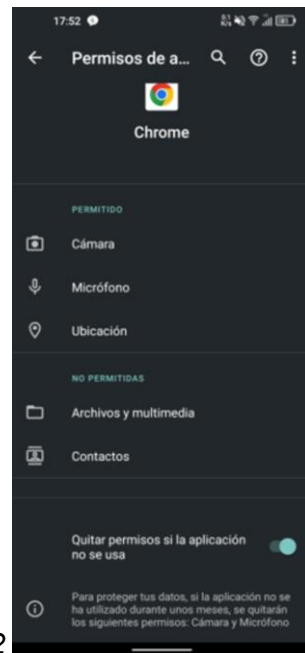


Fig 23

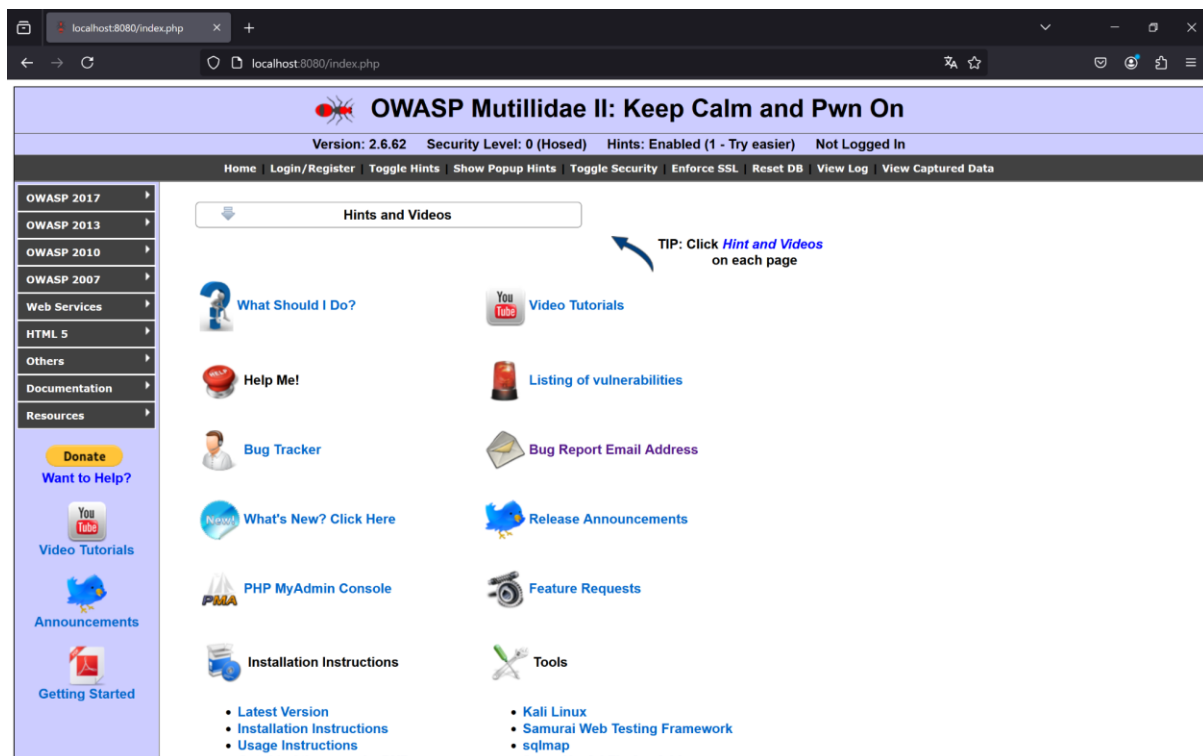


Fig 24

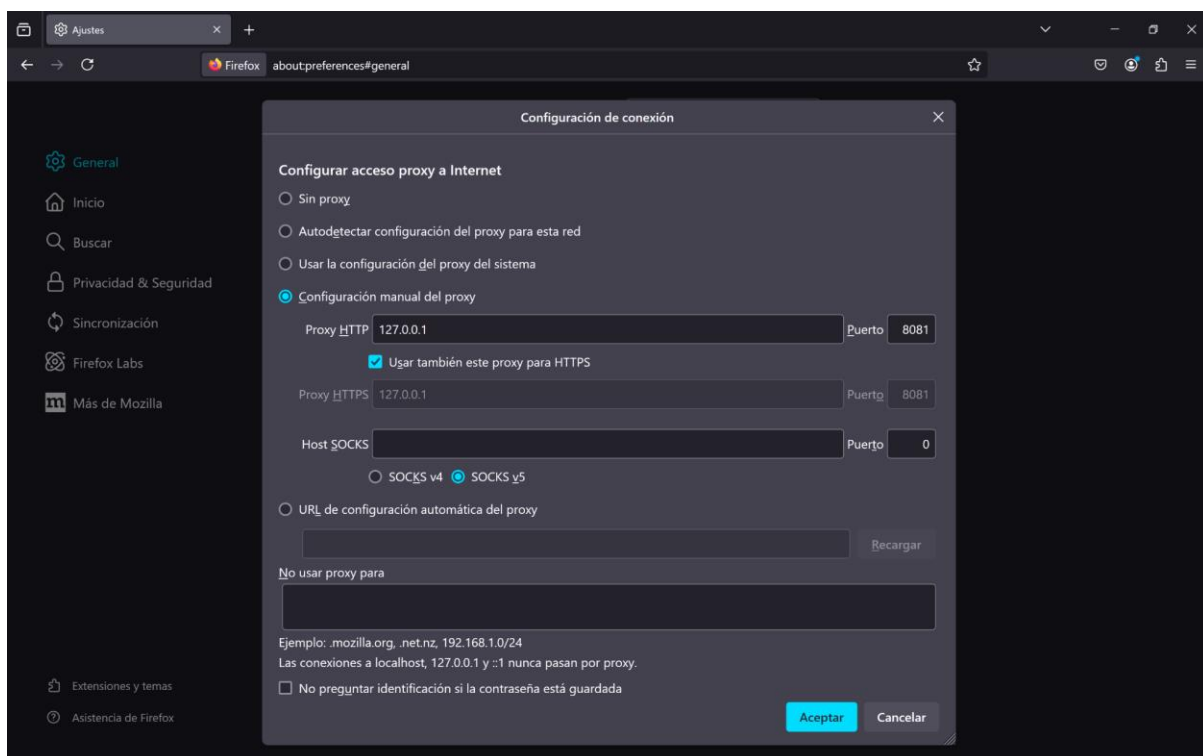


Fig 25

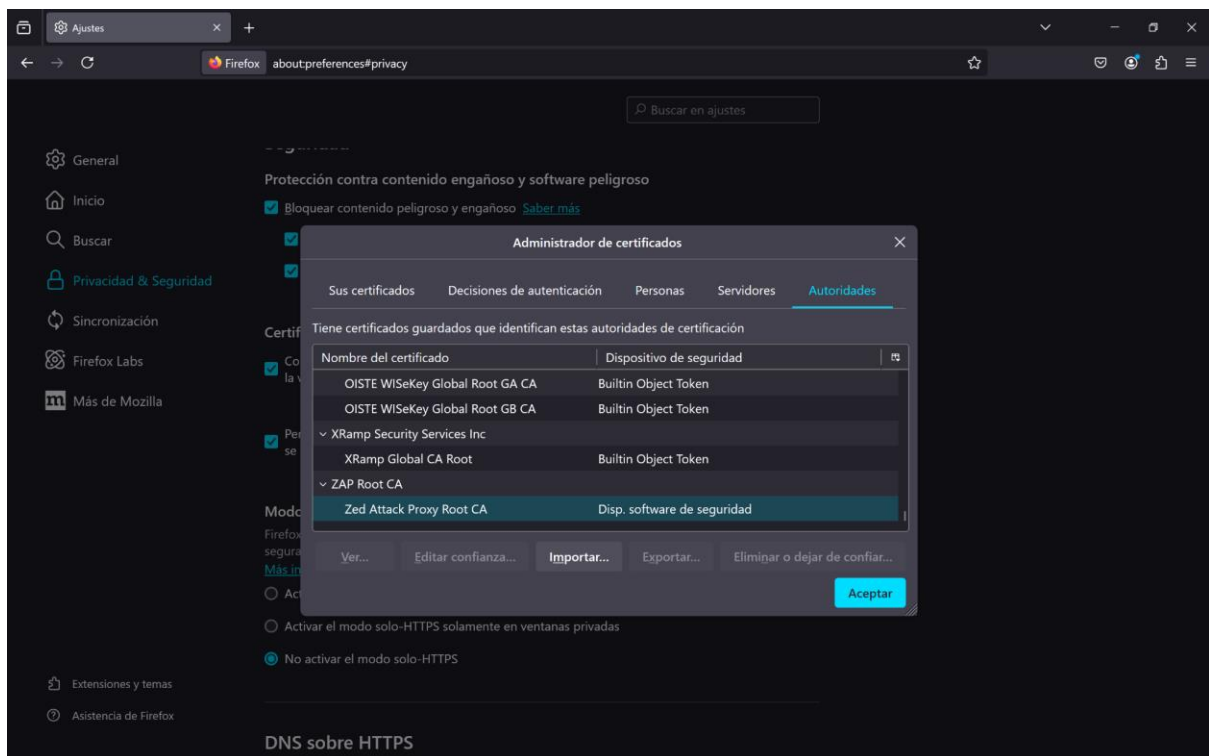


Fig 26

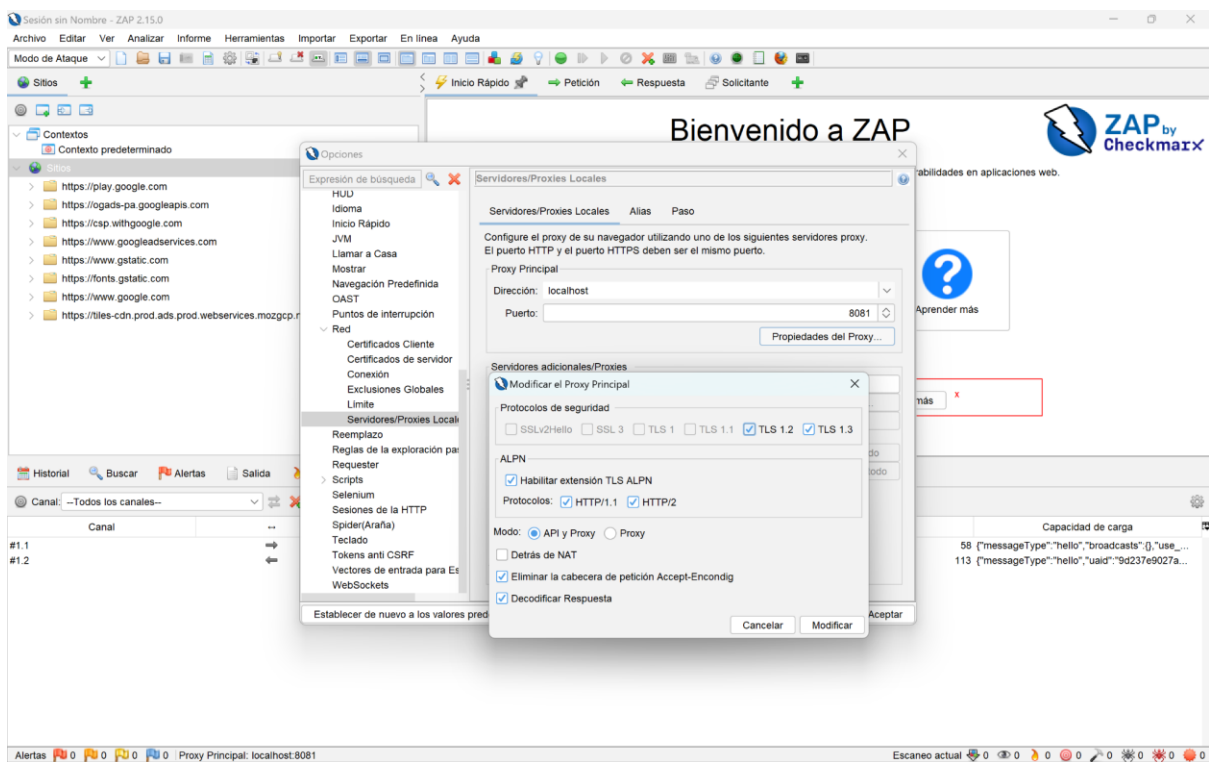


Fig 27

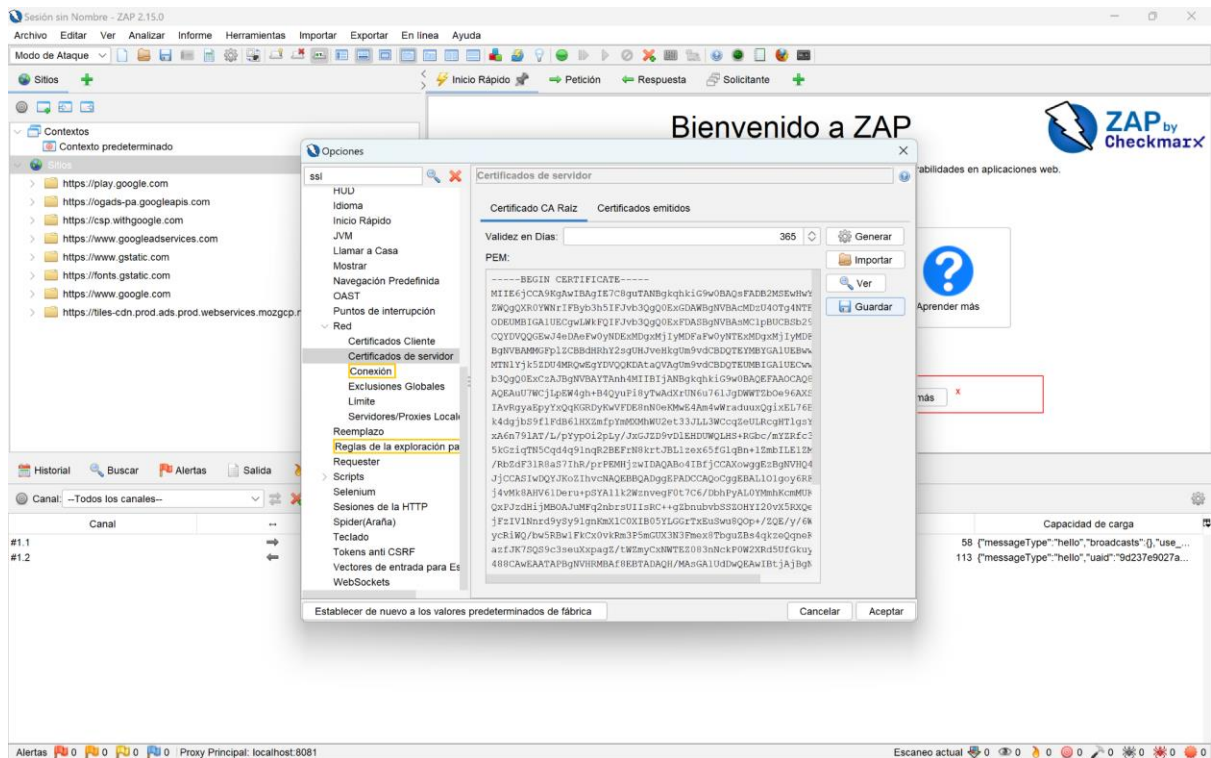


Fig 28

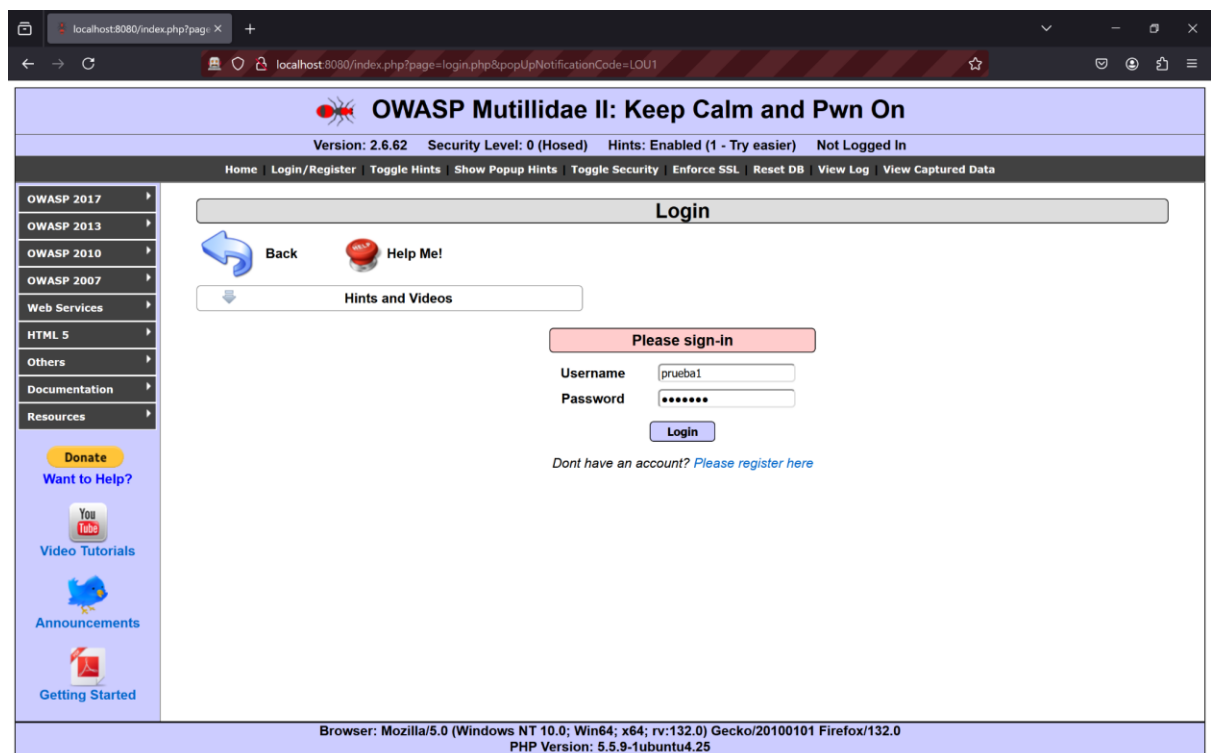


Fig 29

Fig 30

The screenshot shows the Burp Suite interface with the 'Petición' (Request) tab selected. The request is a POST to `http://localhost:8080/index.php?page=login.php` with a body containing `username=prueba1&password=prueba1`. The response is a 302 Found status with a redirect to `http://localhost:8080`.

ID	Fuente	Petición (Tiempo)	Método	URL	Código	Razón	RTT	Respuesta (Tamaño del cuerpo)	Alerta mayor	Nota	Etiquetas
322	Proxy	8/11/24, 21:00:41	GET	http://localhost:8080/styles/ddssmoothmenu/...	200	OK	15ms	1.188bytes			
323	Proxy	8/11/24, 21:00:41	GET	http://localhost:8080/javascript/ddssmoothmenu...	200	OK	21ms	57.254bytes			
324	Proxy	8/11/24, 21:00:41	GET	http://localhost:8080/javascript/Query/colorbo...	200	OK	10ms	9.845bytes			
325	Proxy	8/11/24, 21:00:41	GET	http://localhost:8080/javascript/Query/colorbo...	200	OK	12ms	5.000bytes			
326	Proxy	8/11/24, 21:00:41	GET	http://localhost:8080/styles/global-styles.css	200	OK	21ms	12.022bytes			
327	Proxy	8/11/24, 21:00:41	GET	http://localhost:8080/javascript/Query/query.b...	200	OK	13ms	11.337bytes			
332	Proxy	8/11/24, 21:00:41	GET	http://localhost:8080/javascript/Query/query.js	200	OK	32ms	267.739bytes			
356	Proxy	8/11/24, 21:00:46	GET	http://localhost:8080/index.php?page=login.php	200	OK	29ms	55.022bytes			
358	Proxy	8/11/24, 21:00:53	POST	http://localhost:8080/index.php?page=login.php	302	Found	28ms	0bytes			
359	Proxy	8/11/24, 21:00:53	GET	http://localhost:8080/index.php?popUpNotifica...	200	OK	17ms	53.320bytes			
360	Proxy	8/11/24, 21:00:53	GET	http://localhost:8080/styles/gritter/gritter.css	200	OK	7ms	2.044bytes			
361	Proxy	8/11/24, 21:00:53	GET	http://localhost:8080/javascript/gritter/gritter.g...	200	OK	6ms	4.248bytes			
367	Proxy	8/11/24, 21:03:59	GET	http://localhost:8080/index.php?do=logout	302	Found	22ms	0bytes			
368	Proxy	8/11/24, 21:03:59	GET	http://localhost:8080/index.php?page=login.ph...	200	OK	15ms	55.502bytes			

Fig 30

Fig 31

The screenshot shows the Burp Suite interface with the 'Petición' (Request) tab selected. The request is a POST to `http://localhost:8080/index.php?page=login.php` with a body containing `username=prueba2&password=passwd123`. The response is a 200 OK status with a body containing a message: `User name or password incorrect`.

ID	Fuente	Petición (Tiempo)	Método	URL	Código	Razón	RTT	Respuesta (Tamaño del cuerpo)	Alerta mayor	Nota	Etiquetas
324	Proxy	8/11/24, 21:00:41	GET	http://localhost:8080/javascript/Query/colorbo...	200	OK	10ms	9.845bytes			
325	Proxy	8/11/24, 21:00:41	GET	http://localhost:8080/javascript/Query/colorbo...	200	OK	12ms	5.000bytes			
326	Proxy	8/11/24, 21:00:41	GET	http://localhost:8080/styles/global-styles.css	200	OK	21ms	12.022bytes			
327	Proxy	8/11/24, 21:00:41	GET	http://localhost:8080/javascript/Query/query.b...	200	OK	13ms	11.337bytes			
332	Proxy	8/11/24, 21:00:41	GET	http://localhost:8080/javascript/Query/query.js	200	OK	32ms	267.739bytes			
356	Proxy	8/11/24, 21:00:46	GET	http://localhost:8080/index.php?page=login.php	200	OK	29ms	55.022bytes			
358	Proxy	8/11/24, 21:00:53	POST	http://localhost:8080/index.php?page=login.php	302	Found	28ms	0bytes			
359	Proxy	8/11/24, 21:00:53	GET	http://localhost:8080/index.php?popUpNotifica...	200	OK	17ms	53.320bytes			
360	Proxy	8/11/24, 21:00:53	GET	http://localhost:8080/styles/gritter/gritter.css	200	OK	7ms	2.044bytes			
361	Proxy	8/11/24, 21:00:53	GET	http://localhost:8080/javascript/gritter/gritter.g...	200	OK	6ms	4.248bytes			
367	Proxy	8/11/24, 21:03:59	GET	http://localhost:8080/index.php?do=logout	302	Found	22ms	0bytes			
368	Proxy	8/11/24, 21:03:59	GET	http://localhost:8080/index.php?page=login.ph...	200	OK	15ms	55.502bytes			
371	Manual	8/11/24, 21:17:06	POST	http://localhost:8080/index.php?page=login.php	200	OK	57ms	55.045bytes			

Fig 31

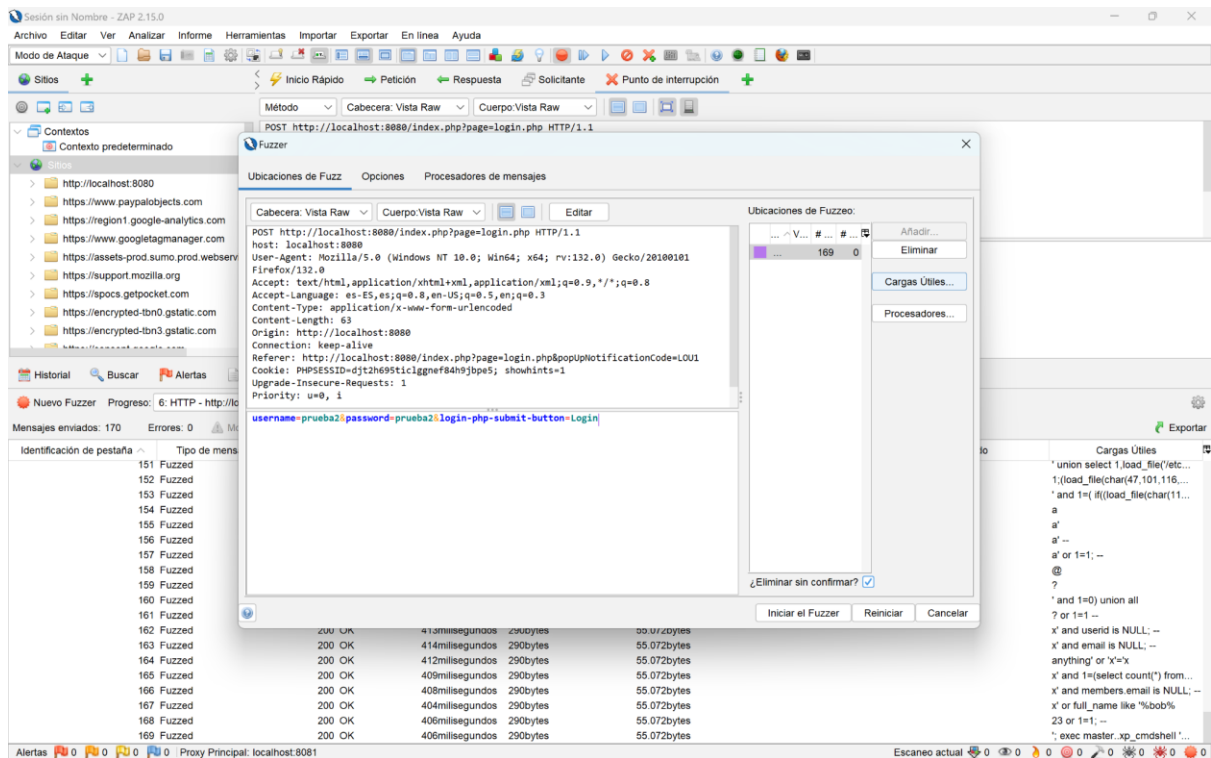


Fig 32

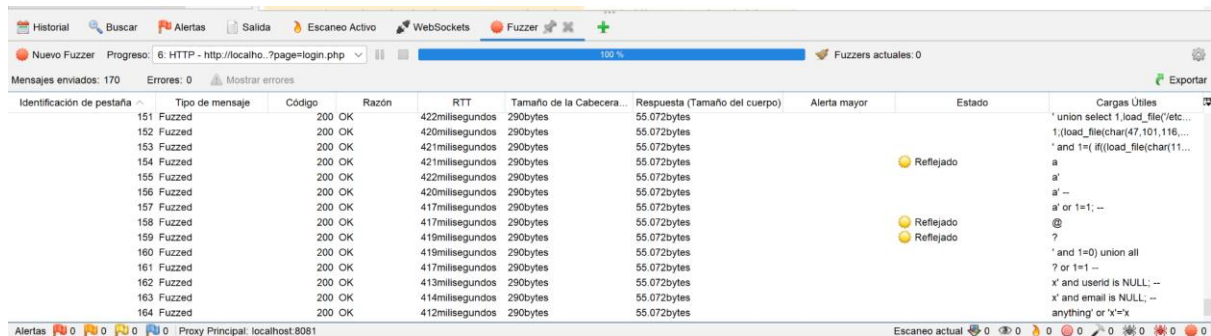


Fig 33

Sesión sin Nombre - ZAP 2.15.0

Archivo Editar Ver Analizar Informe Herramientas Importar Exportar En línea Ayuda

Modo de Ataque Sitios Inicio Rápido Petición Respuesta Solicitante Punto de interrupción

Contextos Contexto predeterminado

- http://localhost:8080
- https://www.paypalobjects.com
- https://region1.google-analytics.com
- https://www.googletagmanager.com
- https://assets-prod.sumo.prod.webservic
- https://support.mozilla.org
- https://spocs.getpocket.com
- https://encrypted-tbn0.gstatic.com
- https://encrypted-tbn3.gstatic.com
- https://consent.google.com
- https://play.google.com
- https://ogads-pa.googleapis.com
- https://csp.withgoogle.com
- https://www.googleadservices.com

Cabecera: Vista Raw Cuerpo: Vista Raw

POST http://localhost:8080/index.php?page=login.php HTTP/1.1
 host: localhost:8080
 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:132.0) Gecko/20100101 Firefox/132.0
 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
 Accept-Language: es-ES,es;q=0.8,en-US;q=0.5,en;q=0.3
 Content-Type: application/x-www-form-urlencoded
 Content-Length: 55
 Origin: http://localhost:8080
 Connection: keep-alive
 Referer: http://localhost:8080/index.php?page=login.php
 Cookie: PHPSESSID=djt2h695t1clggnf84h9jbpe5; showhints=1
 Upgrade-Insecure-Requests: 1
 Priority: u=0, i

username=admin&password=a&login-php-submit-button=Login

Historial Buscar Alertas Salida Escaneo Activo WebSockets Fuzzer

Filtro: APAGADO Exportar

ID	Fuente	Petición (Tiempo)	Método	URL	Código	Razón	RTT	Respuesta (Tamaño del cuerpo)	Alerta mayor	Nota	Etiquetas
374	Proxy	8/11/24, 21:32:53	GET	http://localhost:8080/index.php?popUpNotifica...	200	OK	13milisegundos	53.320bytes			
375	Proxy	8/11/24, 21:32:53	GET	http://localhost:8080/javascript/gitter/query.gr...	200	OK	9milisegundos	4.248bytes			
379	Proxy	8/11/24, 21:39:32	GET	http://localhost:8080/index.php?do=logout	302	Found	22milisegundos	0bytes			
380	Proxy	8/11/24, 21:39:32	GET	http://localhost:8080/index.php?page=login.ph...	200	OK	13milisegundos	55.502bytes			
382	Proxy	8/11/24, 21:40:19	POST	http://localhost:8080/index.php?page=login.php	200	OK	54milisegundos	55.072bytes			
908	Proxy	8/11/24, 21:59:33	POST	http://localhost:8080/index.php?page=login.php	302	Found	81milisegundos	0bytes			
909	Proxy	8/11/24, 22:14:46	GET	http://localhost:8080/index.php?popUpNotifica...	200	OK	40milisegundos	53.320bytes			
912	Proxy	8/11/24, 22:14:54	GET	http://localhost:8080/index.php?do=logout	302	Found	27milisegundos	0bytes			
913	Proxy	8/11/24, 22:14:54	GET	http://localhost:8080/index.php?page=login.ph...	200	OK	14milisegundos	55.502bytes			
1.084	Proxy	8/11/24, 22:16:26	POST	http://localhost:8080/index.php?page=login.php	302	Found	56milisegundos	0bytes			
1.085	Proxy	8/11/24, 22:18:18	GET	http://localhost:8080/index.php?popUpNotifica...	200	OK	32milisegundos	53.320bytes			
1.086	Proxy	8/11/24, 22:18:32	GET	http://localhost:8080/index.php?do=logout	302	Found	17milisegundos	0bytes			
1.087	Proxy	8/11/24, 22:18:32	GET	http://localhost:8080/index.php?page=login.ph...	200	OK	11milisegundos	55.502bytes			
1.258	Proxy	8/11/24, 22:19:03	POST	http://localhost:8080/index.php?page=login.php	200	OK	53milisegundos	55.072bytes			
1.259	Proxy	8/11/24, 22:22:43	POST	http://localhost:8080/index.php?page=login.php	200	OK	43milisegundos	55.045bytes			

Alertas 0 0 0 0 0 0 0 0 0 0 0 0 Escaneo actual 0 0 0 0 0 0 0 0 0 0 0 0

Proxy Principal: localhost:8081

Fig 34

OWASP Mutillidae II: Keep Calm and Pwn On

Version: 2.6.62 Security Level: 0 (Hosed) Hints: Enabled (1 - Try easier) Logged In Admin: admin (g0t m0rt?)

Home Logout Toggle Hints Show Popup Hints Toggle Security Enforce SSL Reset DB View Log View Captured Data

OWASP 2017 OWASP 2013 OWASP 2010 OWASP 2007 Web Services HTML 5 Others Documentation

Login

Back Help Me!

Hints and Videos

You are logged in as admin

Logout

Fig 35